

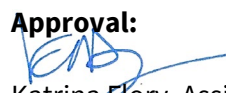


DAS Policy

Security Assessment and Authorization

No:
2100-19

Effective:
March 5, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

The purpose of this policy is to provide information security assessment and Ohio Department of Administrative Services (DAS) Office of Information Security & Privacy (OISP) security approval requirements for ***DAS-Managed Information Systems and Services***.

The first occurrence of a defined term in the policy is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards in Technology (NIST) Special Publication (SP) 800-53 family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable. The requirements of the NIST SP 800-53 Security Assessment and Authorization (CA) control family are addressed in this policy.

II. Scope

The scope of this policy includes all DAS-Managed Information Systems and Services.

III. Policy

A DAS OISP security approval is required for the operation of DAS-Managed Information Systems and Services. The security approval ensures that security controls are assessed prior to placing the system(s) or service(s) into operation. The systems and services are also required to be regularly re-approved to ensure that the appropriate security safeguards are in place.

A. **Information Security Assessments (CA-2)**: An information security assessment shall be completed and must include the following:

1. Information Security Assessment Methodology: An information security assessment methodology shall be developed that describes the scope of the assessment including:

- a) **Data Classification:** A process that identifies what information needs to be protected against unauthorized access, misuse, and the extent to which it needs to be secured and controlled, in accordance with State of Ohio Administrative policy IT-13, “Data Classification.”
 - b) **Privacy Assessment:** A privacy assessment examines a business process or system of an agency with a focus on the perspective of the people whose information will be in the system. Specifically, **Personally Identifiable Information (PII)**. Conducting a privacy threshold assessment (PTA) will determine if a privacy impact assessment (PIA) is required. Refer to sections 128.18 and 1347.15 of the Ohio Revised Code.
 - c) **Risk Assessment:** The risk assessment practice is designed to identify potential threats, associated impact, and the likelihood of the threat occurring, in accordance with DAS Policy 2100-08, “Risk Assessment.”
 - d) **Security Plan:** A security plan shall be developed that aligns with the security controls in NIST SP 800-53 (Revision 4).
 - e) **Penetration Testing (CA-8):** Penetration Testing of Internet-facing systems shall, as a minimum, be conducted every two years, and annually for **Business Critical IT System Assets or Services** to identify any potential weaknesses in security controls. Penetration Testing shall be conducted on a more frequent basis when indicated by the results of the information system or service risk assessment.
2. **Assessment Frequency:** Security controls in DAS-Managed Information Systems and Services shall be assessed to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting established security requirements. At a minimum, the assessment frequency shall be:
- a) Prior to and after implementing proposed **Significant Changes**;
 - b) After a security incident; or
 - c) Every two years.
- The security plan shall be updated to include new or modified security controls.
3. **Assessment Maintenance:** The results of the security controls assessment shall be included in the information system or service security approval package and maintained by DAS OISP.
4. **Assessment Independence:** When DAS-managed systems and services are assessed as high criticality and/or high confidentiality, independent assessors and assessment teams shall be used to conduct security control assessments.
- B. **Remediation Plan (CA-5):** When findings of weaknesses or deficiencies are a result of an information security assessment, a remediation plan shall be developed for DAS-Managed Information Systems and Services. The remediation plan shall document weaknesses or deficiencies identified during the information security assessment and the remedial actions required to correct said weaknesses or deficiencies. The remediation plan shall also include

plans to reduce or eliminate known vulnerabilities in the system. The system or service owner, in consultation with DAS OISP, shall update the remediation plan based on the findings from security controls assessments, security impact analyses, and continuous monitoring activities.

- C. **DAS OISP Security Approval:** Each DAS-managed information system or service shall be assigned an authorizing official, who is responsible for budgetary oversight and the mission/business functions supported by the system or service. The authorizing official shall not authorize the system or service to operate until it has been granted a security approval by the State CISO. The information system or service security approval shall be updated every two years, or after a major system upgrade or service modification.

The DAS OISP security approval process consists of four phases:

1. Information Security Assessment Documentation: The system or service owner shall provide the security documentation required in section A.1. Also, a schedule shall be developed by DAS OISP for the IT security review, provisional security approval, and DAS OISP security approval.
2. IT Security Review: DAS OISP shall conduct a review of the documentation submitted in accordance with section A.1. of this policy. In addition, the system or service owner shall work with DAS OISP and the State of Ohio Office of Procurement Services, when appropriate, to ensure that the vendor completes a questionnaire provided by DAS OISP. DAS OISP shall also include the questionnaire response in the IT security review.
3. Provisional Security Approval: Contingent upon a favorable DAS OISP review of the security documentation, a provisional security approval will be provided by DAS OISP. This provisional security approval will grant the system or service owner the approval to move forward with development and implementation.
If a contract is involved, the provisional security approval must occur prior to contract award. Any state contract which involves a vendor gaining access to state data or systems shall not be entered into without provisional security approval.
4. DAS OISP Security Approval: Based upon a favorable review of the updated security plan, risk assessment documentation (refer to sections A.1. and A.1.c.), and remediation plan (refer to section B.), a DAS OISP security approval shall be granted by the State CISO to the authorizing official.

- D. **Continuous Monitoring (CA-7):** DAS OISP shall develop and implement a continuous monitoring strategy for security controls. This strategy shall include:

1. Metrics to monitor DAS-Managed Information Systems and Services.

2. Monitoring frequencies based upon the results of the information system or service risk assessment.
 3. Ongoing security status monitoring of information system or service metrics that are reviewed and updated, as needed, every two years.
 4. Quarterly reporting of the security status of the information system or service to the system or service owner, or their designee.
- E. **Penetration Testing (CA-8):** Penetration Testing of Internet-facing systems shall, as a minimum, be conducted every two years, and annually for higher risk systems. Penetration Testing shall be conducted on a more frequent basis when indicated by the results of the information system risk assessment.
- F. **Procedures:** DAS OISP will provide detailed procedures to DAS entities as part of the security assessment and authorization process.
- G. **Exception Process:** To request an exception to one or more of the requirements outlined in this policy, please complete an IT Security Exception Request form.
1. The form is located within the IT Enterprise Services Portal under the "Services & Products" category.
 2. If you have any questions, please contact DAS OISP (refer to Section VII. Inquiries for contact information).

IV. Definitions

- A. Business Critical IT System Assets or Services: Assets, systems, or services that are identified as having the greatest potential to impact the achievement of the organizational mission.
- B. DAS-managed Information Systems and Services: A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.¹ This includes internal DAS information systems as well as information systems and infrastructure (services) operated or managed by DAS for customer agencies. For the purposes of this policy, primary responsibility for managing these systems or services may be assigned to DAS OIT personnel or other outside entities.
- C. DAS-Managed System Asset: Information, hardware, software and services required to support state business, and identified during the risk assessment process as assets that need to be protected. Primary responsibility for managing these system assets may be assigned to DAS OIT personnel or other outside entities.
- D. Penetration Testing. A test methodology in which assessors, typically working under

¹ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

specific constraints, attempt to circumvent or defeat the security features of an information system.²

- E. Personally Identifiable Information (PII). “Personally identifiable information” is information that can be used directly or in combination with other information to identify a particular individual. It includes:
 - 1. a name, identifying number, symbol, or other identifier assigned to a person,
 - 2. any information that describes anything about a person,
 - 3. any information that indicates actions done by or to a person,
 - 4. any information that indicates that a person possesses certain personal characteristics.³
- F. Significant Change. For the purposes of this policy, a Significant Change is defined as substantial changes that alter the mission, configuration or basic vulnerabilities of a **DAS-Managed System Asset** (e.g., changes to business requirements, hardware, application programs, external users, telecommunications, location of the IT system, or IT system interfaces).

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
Ohio Revised Code 1347.12	https://codes.ohio.gov/ohio-revised-code
State of Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-08 Risk Assessment	https://das.ohio.gov/technology-and-strategy/policies

² “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

³ Based on Ohio Revised Code Section 1347.01 (E).

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
12/21/2018	Original Policy.
06/10/2020	Updated the policy template.
08/02/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated to clarify the applicable NIST SP 800-53 version. Updated the policy template. Added a revision history review frequency statement.